

21 JULY 2026

OPENCTI

FROM DOCKER DEPLOYMENT TO CTI CAPABILITY

Technical implementation guide for maritime, ship, port, logistics and transportation security operations

Confirmed starting point: OpenCTI is deployed with Docker. The current version, topology, connectors, source inventory, security controls, backup status and Elastic integration are unknown and must be validated before production changes.

Document control	Value
Work item	XXXX
Purpose	Build a controlled path from an existing Docker deployment to an operational CTI capability
Primary consumers	CTI analysts, threat hunters, detection engineers, SOC, incident response and platform engineering
Status	Implementation blueprint - environment-specific values pending discovery

The design prioritizes behavior, relevance, source quality, data lifecycle and analyst decisions over bulk IOC ingestion.

0. How to use this guide	3
1. Executive implementation decision	5
2. Scope, assumptions and non-goals	7
3. Phase 0 - discover the existing Docker deployment	9
4. Target architecture for a controlled Docker deployment	12
5. Maritime intelligence requirements before feeds	14
6. Build the maritime knowledge model	16
7. Source and connector onboarding strategy	18
8. Confidence, deduplication and indicator lifecycle	20
9. RBAC, markings and information-sharing boundaries	22
10. Analyst workflow and operational runbook	24
11. OpenCTI to Elastic Security: controlled delivery	26
12. Priority maritime and transportation use cases	28
13. Convert intelligence into durable hunts and detections	30
14. Acceptance testing and validation plan	32
15. implementation roadmap	34
16. Metrics that demonstrate utility without invented ROI	36
17. Production runbook - minimum procedures	38
18. Implementation checklist	40
19. Authoritative references	41
20. EXTERNAL ENRICHMENT PRIVACY AND REQUIRED INFORMATION	43

0. HOW TO USE THIS GUIDE

The document is organized as an implementation sequence. Sections 1-4 establish the decision and platform baseline, sections 5-10 design the intelligence operating model, sections 11-14 operationalize and validate, sections 15-18 provide delivery control, section 19 lists authoritative sources.

Section	Primary output
1. Executive implementation decision	Definition of done for XXXXX
2. Scope, assumptions and non-goals	Confirmed facts, unknowns and design boundaries.
3. Phase 0 discovery	Docker/OpenCTI evidence and go/no-go gate.
4. Target architecture	Controlled deployment and trust boundaries.
5-9. Intelligence design	PIRs, knowledge model, connectors, quality, RBAC and markings.
10. Analyst workflow	Review, approval, dissemination and feedback runbook.
11-13. Operationalization	Elastic delivery, maritime use cases, hunts and detections.
14. Acceptance testing	Technical and operational go-live evidence.
15. Roadmap	Phases and suggested XXXXX subtasks.
16-18. Operating control	Metrics, production runbook and final checklist.
19. References	Official sources and evidence needed for environment-specific revision.

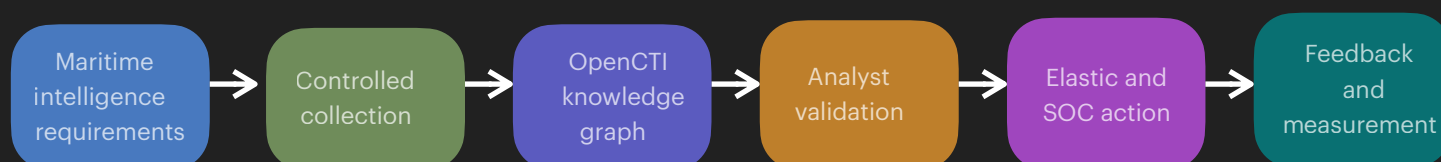
Safe use: commands are discovery examples, not authorization to change production. Run them through the approved administration path, sanitize outputs, and do not attach secrets or unrestricted configuration to **XXXX**.

Environment-specific revision trigger

After Phase 0 evidence is available, revise this guide with exact versions, service names, topology, connectors, source licenses, RBAC groups, markings, Elastic mappings, backup/restore procedures and local acceptance thresholds. Until then, all such values remain unknown.

1. EXECUTIVE IMPLEMENTATION DECISION

OpenCTI should be treated as the intelligence knowledge and workflow layer between sources and defensive consumers. It is not a replacement for Elastic Security, EDR, case management or analyst judgment. Its value is created when structured, confidence-scored and time-bounded intelligence changes a hunt, detection, investigation or risk decision.



Recommended initial outcome

- **One production use case:** prioritize intelligence relevant to shipboard IT/OT, port operations, maritime logistics, identity, remote access and supply-chain compromise.
- **One controlled data path:** two or three trusted import sources, one enrichment path, and one filtered delivery mechanism to Elastic.
- **One governed workflow:** New -> Triage -> Assessed -> Approved for detection/hunt -> Disseminated -> Expired/Revoked.
- **One validation case:** trace a report or indicator through ingestion, relationships, scoring, Elastic delivery, analyst decision and feedback.

Do not begin by enabling every connector. Bulk ingestion without requirements, confidence controls, markings and expiry logic creates a larger data problem and can degrade SIEM signal quality.

Definition of done for XXXX

Capability	Minimum acceptance evidence
Platform baseline	Versioned compose files, container/image inventory, health status, capacity snapshot, owner and backup/restore test.
Governance	Approved PIRs, source register, confidence model, markings, RBAC groups, indicator lifecycle and review workflow.
Data	At least two approved sources; provenance preserved; duplicates and stale indicators tested.
Operations	Analyst runbook, RFI path, escalation rules, weekly quality review and connector failure alerting.
Elastic delivery	Filtered output with documented inclusion/exclusion criteria; revocation/update behavior verified.
Measurement	Baseline and target for coverage, source quality, timeliness, stale IOC rate and hunt/detection conversion.

2. SCOPE, ASSUMPTIONS AND NON-GOALS

Classification	Statement
Confirmed	OpenCTI exists in Docker. The intended business domain is maritime and transportation.
Unknown	OpenCTI version, Docker host design, internet exposure, SSO, TLS, secrets handling, enabled connectors, licensing, API consumers, backup state and production SLAs.
Target	A controlled CTI platform that supports prioritized intelligence, hunting, detection engineering, incident enrichment and reporting.
Non-goal	Sending all OpenCTI indicators directly into high-severity Elastic alerts.
Non-goal	Treating vendor verdicts, VirusTotal counts or a single feed as confirmation of maliciousness or attribution.

Design principles

- **Requirements before collection:** every source and connector must answer a PIR or operational requirement.
- **Provenance before confidence:** preserve created-by, source, external references, dates, markings and original report context.
- **Behavior before indicators:** use IOCs for enrichment, triage and short-lived containment; convert durable intelligence into ATT&CK-mapped; hunts and detections.
- **Evidence before attribution:** actor or campaign relationships require corroboration and explicit confidence.
- **Lifecycle before dissemination:** define valid-from, valid-until, score decay, revocation and downstream update behavior before SIEM delivery.
- **Ship safety context:** intelligence prioritization must account for operational and safety consequences, not only confidentiality and malware prevalence.

Maritime scope boundary

This guide covers intelligence about threats affecting vessel IT, shipboard OT and computer-based systems, shore-to-ship connectivity, fleet management, ports and terminals, logistics platforms, identity services, satellite/remote access, vendors and software supply chains. It does not prescribe changes to safety-critical ship systems. Any active testing or blocking involving operational technology requires vessel owner, engineering and safety approval.

IMO defines maritime cyber risk in terms of shipping-related operational, safety or security failures and frames the goal as safe, secure and operationally resilient shipping [1].

3. PHASE 0 - DISCOVER THE EXISTING DOCKER DEPLOYMENT

The first technical task is not to add a feed. It is to establish what exists, whether it is supportable, and whether evidence can be recovered after failure. Run discovery read-only where possible and store sanitized outputs with XXXX.

Baseline commands

```
# Run from the OpenCTI Docker project directory
docker compose config --images
docker compose ps
docker compose images
docker compose logs --since 24h --no-color opencti worker
docker inspect <container> --format '{{.Config.Image}}
{{.State.Status}}'
docker stats --no-stream
docker volume ls
# Capture non-secret compose metadata
docker compose config --services
docker compose config --volumes
curl -fsSI https://<opencti-host>/health
```

Evidence to collect

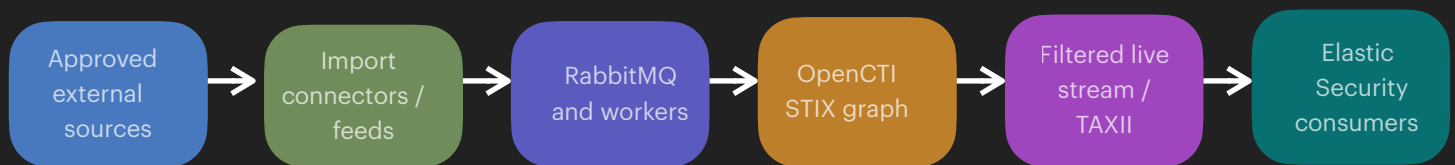
Area	Questions and evidence
Ownership	Who administers Docker, OpenCTI, connectors, sources, RBAC, backups and Elastic integration?
Topology	Host OS, CPU/RAM/disk, reverse proxy, TLS termination, DNS, network zones, outbound internet and admin paths.
Components	OpenCTI, workers, Elasticsearch/OpenSearch, Redis, RabbitMQ, MinIO/S3, connectors and monitoring components.
Persistence	Named/bind volumes, filesystem location, encryption, capacity, retention and snapshot method.
Security	SSO/MFA, local admin accounts, secrets storage, service tokens, image pinning, vulnerability scanning and ingress restrictions.
Health	Worker queue, connector status, ingestion errors, index health, RabbitMQ backlog, object-store health and disk utilization.
Recovery	Last successful backup, restore instructions, restore test date, recovery time and recovery point objectives.

Go/no-go gate

Proceed when	Stop and remediate when
Version and images are known and pinned; compose is under change control, health is stable, backups are restorable, credentials are controlled.	Unknown admin ownership, unencrypted public exposure, mutable latest tags, missing persistence, no restore path, repeated queue/index errors, secrets embedded in shared files.

4. TARGET ARCHITECTURE FOR A CONTROLLED DOCKER DEPLOYMENT

OpenCTI uses a graph-based STIX 2.1 model. In the standard Docker deployment, the application depends on workers and supporting services such as Elasticsearch/OpenSearch, Redis, RabbitMQ and MinIO/S3. The official deployment documentation recommends persistent volumes and documents required host and dependency configuration [2].



Security zones and trust boundaries

Zone	Contents	Minimum controls
User access	Analyst browser, API clients	HTTPS, SSO/MFA where available, named accounts, least privilege, admin access restricted.
Application	OpenCTI API/UI, workers	No direct public exposure, reverse proxy, health monitoring, version-pinned images.
Data services	Search engine, Redis, RabbitMQ, object storage	Private network only, authentication, persistent volumes, backup, capacity alerts.
Connector egress	Import/enrichment/stream containers	Dedicated service identities, allowlisted destinations, separate tokens, resource limits, logs.
Consumer path	Elastic stream/TAXII/API	Filter at source, preserve provenance and markings, test create/update/delete/revoke behavior.

Docker hardening checklist

- Pin every platform and connector image to an approved version or digest; do not use floating latest tags in production.
- Keep .env and API tokens out of source repositories and Jira attachments, use a secrets manager or protected host files.
- Do not publish Elasticsearch/OpenSearch, Redis, RabbitMQ or MinIO ports to untrusted networks.
- Apply CPU/memory limits and log rotation; monitor disk, queue depth, worker errors and connector work status.
- Back up the search datastore and object storage consistently; document whether other state is reconstructed or protected.
- Test upgrade and restore in staging. Review release notes and connector compatibility before production upgrades [\[3\]](#).

A running container is not evidence of a production-ready CTI service. Production readiness requires recoverability, access control, observability, ownership and tested data behavior.

5. MARITIME INTELLIGENCE REQUIREMENTS BEFORE FEEDS

PIRs decide what the platform should collect, relate, prioritize and disseminate. They should be specific enough to drive a data source, a query, an owner and an action.

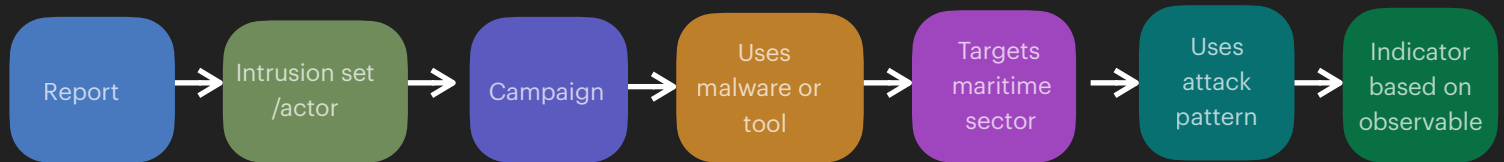
Priority intelligence requirement	Primary scope	Decision or action
PIR-01: Which actors and campaigns currently target maritime, shipping, ports, logistics or transportation organizations?	Intrusion sets, campaigns, victim sectors, geography, motivation, targeting history.	Prioritize hunt and detection coverage, brief fleet/shore leadership.
PIR-02: Which behaviors threaten shore-to-ship access and remote administration?	VPN, RMM, remote desktop, satellite links, vendor support paths, credential theft.	Review exposed services, authentication controls and telemetry, build behavioral hunts.
PIR-03: Which vulnerabilities are exploited in technologies present in our fleet and shore environment?	Asset/software inventory, KEV/exploitation evidence, vendor advisories, exposure.	Patch or mitigate based on relevance and exploitation, not CVSS alone.
PIR-04: Which supply-chain threats affect maritime software, service providers and logistics platforms?	Vendors, software, certificates, update mechanisms, third parties and dependencies.	Supplier review, targeted monitoring, detection and incident readiness.
PIR-05: Which intelligence indicates potential disruption or unsafe operational impact?	Wipers, ransomware, destructive activity, navigation/communication dependencies and port operations.	Escalate to incident, business continuity, vessel engineering and safety stakeholders.

Collection requirement template

Field	Example
Requirement ID	PIR-02 / CR-02.1
Question	Are threat actors exploiting remote access used by vessel vendors?
Needed objects	Threat actor, campaign, attack pattern, tool, vulnerability, infrastructure, report, relationship, sighting.
Sources	Internal IR, approved vendor reporting, ISAC/ community reporting, vulnerability/exploitation authorities.
Time window	Active or updated within 90 days; longer for durable TTP context.
Consumer/action	Threat hunting and detection engineering, remote-access control review.
Success evidence	At least one validated hunt/detection/control decision or documented no-finding conclusion.

6. BUILD THE MARITIME KNOWLEDGE MODEL

OpenCTI represents knowledge as entities and relationships based on STIX 2.1. Nodes describe entities, edges describe relationships, sightings and other links [4]. The design should model context, not merely store observables.



Recommended entity mapping

Concept	OpenCTI/STIX representation	Modeling guidance
Adversary	Intrusion Set or Threat Actor	Do not create a new actor from an IOC. Maintain aliases and source references.
Operation	Campaign	Use time-bounded campaign identity and explicit actor relationship with confidence.
Behavior	Attack Pattern linked to MITRE ATT&CK	Map only observed or reported behavior, retain source and dates.
Capability	Malware, Tool, Vulnerability	Separate malware family, legitimate tool and exploited vulnerability.
Infrastructure	Infrastructure plus observables/indicators	Separate observed IP/domain from an Indicator pattern; retain validity and score.
Victimology	Sector, Organization, Location	Use maritime, transportation, logistics, port/terminal and geography consistently.
Internal evidence	Observed Data, Sighting, Incident, Report	Avoid uploading sensitive client evidence without approved markings and access boundaries.

Maritime labels are filters, not substitutes for relationships

- Suggested labels:

```
sector:maritime, sector:shipping, sector:ports, sector:logistics,  
environment:vessel-it, environment:vessel-ot, access:shore-to-  
ship.
```

- Use an Asset or dedicated internal inventory outside OpenCTI for exact fleet configuration unless a governed model and access requirement exists.
- Do not encode assessment in a label such as confirmed-bad without a defined workflow and evidentiary standard.

Example analytical chain: a report states that a campaign targets shipping companies and uses a remote management tool. Model the report, campaign, actor if supported, target sector, tool, ATT&CK; behavior and source relationships. Then create indicators only where the report provides valid observable patterns.

7. SOURCE AND CONNECTOR ONBOARDING STRATEGY

OpenCTI connector classes include import, enrichment, stream, import-file and export-file connectors [5]. Each connector must have a dedicated identity, owner, purpose, confidence ceiling, markings and failure path.

Wave	Candidate sources	Purpose	Risk controls
0 - Internal	Internal incident reports, validated sightings, red-team findings, detection/hunt findings.	Highest relevance, build organizational memory.	Client segregation, approval, evidence retention, named producer.
1 - Authoritative	MITRE ATT&CK, CISA KEV or national CERT advisories, approved vendor advisories.	Behavior and exploitation context.	Validate licensing and update cadence, keep original references.
2 - Community	Approved ISAC/community TAXII or MISP source, if membership permits.	Sector targeting and campaign context.	TLP/usage controls; source reliability, organization-specific access.
3 - Enrichment	VirusTotal, passive DNS, WHOIS/RDAP, sandbox, reputation services.	Add evidence to analyst-led assessment.	API license, rate limit, privacy, never treat engine count alone as confirmation.
4 - Broad OSINT	RSS, reports, generic feeds.	Discovery and context.	Require deduplication, relevance filters, confidence ceiling and expiry.

Connector registration record

Required Field	Example Decision
Business purpose	Supports PIR-03 by importing exploited-vulnerability evidence.
Connector type and image	External import, version/digest pinned and approved.
Service user/token	Dedicated identity, token stored outside compose repository.
Confidence ceiling	Cannot overwrite higher-confidence analyst-validated knowledge.
Marking/default author	Source organization recorded, default marking approved.
Scope/frequency	Only required object types, polling interval within license and operational need.
Lifecycle	First/last seen, valid-until, decay/revoke behavior and deletion semantics tested.
Owner/SLA	Named operator, alert if no successful work for agreed interval.
Rollback	Disable connector, preserve evidence, assess bad writes and remediate affected objects.

Pilot limit

Start with no more than two import sources and one enrichment source. Review volume, duplicate rate, relevance, markings, relationship quality, worker health and analyst usefulness for two weeks before expansion.

8. CONFIDENCE, DEDUPLICATION AND INDICATOR LIFECYCLE

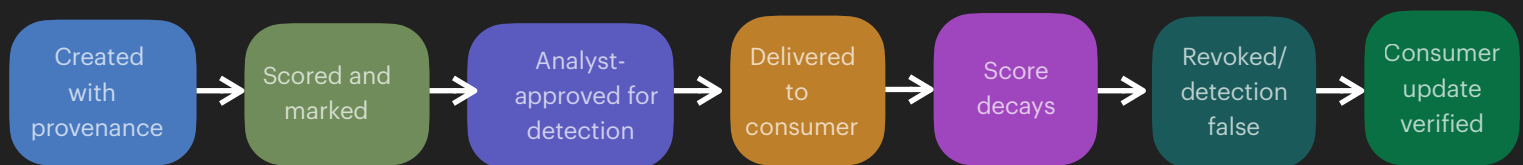
OpenCTI deduplicates objects using deterministic identifying properties and uses confidence controls when incoming knowledge updates existing entities [6]. This is useful, but it does not remove the need for source governance or analyst review.

Control	Policy starter	Validation
Source reliability	Maintain a source register based on history, transparency, access and correction behavior.	Quarterly review, record false reports and correction response.
Information confidence	Use a documented 0-100 or Admiralty-aligned scale. Separate source reliability from claim confidence where maturity permits.	Two analysts score the same sample and reconcile differences.
Connector max confidence	Assign per-source ceiling so low-trust automation cannot overwrite high-confidence knowledge.	Attempt controlled update below and above existing confidence.
Deduplication	Test indicator pattern, entity alias and relationship time-window behavior before bulk ingestion.	Import the same and slightly modified bundles, review result.
Indicator decay	Configure by observable type/ source/marking. Expired indicators must be revoked and detection disabled.	Advance a test indicator through valid-until and verify downstream removal/update.
Attribution	Require multiple independent evidence types and confidence language.	Peer review actor/ campaign relationships.

Assessment language

Classification	Minimum meaning
Confirmed malicious	Direct evidence supports malicious behavior or a trusted authoritative verdict is independently corroborated.
Suspicious	One or more risk signals exist, but benign alternatives or evidence gaps remain.
Likely benign	Context and evidence favor legitimate activity; monitoring or documentation may still be appropriate.
Unknown	Available evidence is insufficient. State exactly what telemetry or source is required.

Indicator lifecycle



OpenCTI uses valid-from/valid-until values, score decay and revocation, after expiry the indicator is revoked and its detection field is set to false [7]. Downstream behavior must be tested because a SIEM copy that never receives updates can remain stale even when OpenCTI is correct.

9. RBAC, MARKINGS AND INFORMATION-SHARING BOUNDARIES

Roles control capabilities; groups combine roles with allowed markings and other defaults. Markings are the core data-segregation mechanism [8]. Design them before importing client-sensitive or partner-restricted intelligence.

Group	Capabilities	Allowed data
Platform administrators	Configuration, connectors, users, system health, minimal analytical editing.	Operational access, bypass only where explicitly required.
CTI analysts	Create/update knowledge, reports, relationships, workflows and approved sharing.	TLP and client/organization markings appropriate to role.
Threat hunters / detection engineers	Read approved knowledge, create notes/sightings/feedback, access filtered technical intelligence.	No default access to unrelated client-restricted data.
SOC analysts	Read operational reports/indicators and submit sightings or feedback.	Only knowledge necessary for triage and response.
Connector identities	Only capabilities needed for connector scope, confidence ceiling set.	Dedicated source marking and author, no interactive login.

Minimum marking policy

- Use FIRST TLP 2.0 labels correctly: **TLP:RED**, **TLP:AMBER**, **TLP:GREEN** and TLP:CLEAR; support **TLP:AMBER+STRICT** where required [9].
- Add organization/client markings where contractual segregation is required, TLP alone does not identify a client boundary.
- Define default markings for reports, sightings, incidents and connectors.
- Configure maximum shareable markings for feeds, exports and public dashboards.
- Test whether relationships or inferred knowledge expose restricted information to users who can see only one endpoint.

Do not ingest restricted maritime partner or client intelligence until the access model has been tested with representative accounts. A correct TLP label does not compensate for incorrect group permissions

10. ANALYST WORKFLOW AND OPERATIONAL RUNBOOK

OpenCTI workflows can track processing status and assign owners or participants to supported objects [10]. The workflow should make review state visible and prevent automatic dissemination of unassessed content.



Stage	Analyst actions	Exit criteria
New	Verify provenance, marking, object type, dates and connector/source identity.	Required metadata exists; malformed or prohibited content quarantined.
Triage	Map to PIR, maritime assets/sectors, geography, current exposure and potential safety/operational consequence.	Relevant and assigned, or explicitly deprioritized with reason.
Assess	Corroborate behavior/indicator, review confidence, alternative explanations, relationships and ATT&CK, mapping.	Assessment and gaps documented, no unsupported attribution.
Operationalize	Choose briefing, hunt, detection, block, vulnerability action, watchlist or no action.	Named consumer and action, expiry/review date set.
Disseminate	Apply filters and markings, preserve context and response guidance.	Consumer receipt and handling boundary confirmed.
Feedback	Record sighting, detection result, false positive, incident link or no finding.	Knowledge, detection and source assessment updated.

Required analyst note

```
Assessment: Confirmed malicious | Suspicious | Likely benign |  
Unknown  
Confidence: Low | Moderate | High  
PIR / consumer:  
Observed evidence:  
Missing evidence / alternative explanations:  
Maritime relevance and affected technology:  
ATT&CK mapping and source:  
Recommended action and owner:  
Review / expiry date:  
Marking and sharing boundary:
```

11. OPENCTI TO ELASTIC SECURITY: CONTROLLED DELIVERY

OpenCTI supports live streams and connector-based delivery to third-party systems such as SIEM/XDR platforms [5,11]. The design objective is not maximum IOC count. It is a filtered, traceable and reversible intelligence stream.

Export gate	Recommended rule
Relevance	Matches maritime/transportation PIR, technology, geography, active campaign or internal sighting.
Confidence	Meets approved threshold; source and information confidence are known.
Lifecycle	Indicator is active, not revoked, detection=true, and valid-until is present or governed by decay.
Context	Created-by/source, external reference, labels, markings, first/last seen and related report/campaign retained where supported.
Safety	No automatic block solely from low-context external IOC, blocking requires separate approval based on impact and evidence.
Update semantics	Create, update, revoke and delete/expiry paths tested end-to-end.

Recommended Elastic patterns

- **Threat-match rule:** use as one signal, enriched with host/user/process/network context; avoid treating the match alone as confirmed malicious.
- **Contextual enrichment:** attach OpenCTI score, confidence, source, validity, related campaign and ATT&CK; context to an investigation.
- **Behavioral detection:** use campaign/TTP intelligence to create EQL, KQL, ES|QL or Sigma logic with ancestry, frequency, baseline and environment context.
- **Sightings feedback:** send validated internal observations back into OpenCTI only through an approved process, do not convert every alert into a sighting.

Example decision logic - conceptual, field names must be validated

```

Deliver indicator only if:
active == true AND revoked == false AND detection == true
AND confidence >= approved_threshold
AND valid_until > now()
AND maritime_relevance == true
Alert severity must also consider:
endpoint/network evidence + asset criticality + user/process
context
+ internal prevalence + source reliability + alternative
explanations

```

Field mappings and connector behavior depend on the installed OpenCTI/connector/Elastic versions. Validate against a staging index before enabling production rules.

12. PRIORITY MARITIME AND TRANSPORTATION USE CASES

Use case	OpenCTI knowledge	SOC/hunt/detection action
Remote access abuse	Actor/campaign -> uses RMM/VPN/RDP behavior -> targets maritime/logistics.	Hunt new or rare remote tools, unusual vendor accounts, off-hours access, unexpected geographies and abnormal parent-child/network context.
Credential theft and identity compromise	Phishing campaign, credential theft ATT&CK, patterns, domains, infrastructure and victimology.	Correlate mail, identity, endpoint and network telemetry, detect impossible travel, token abuse, suspicious mailbox rules and post-authentication behavior.
Ransomware or destructive activity	Actor/campaign, malware, tools, lateral movement, inhibit recovery and impact behavior.	Prioritize behavior chains, verify segmentation, backups, privileged access and vessel/shore operational dependencies.
Exploited maritime/transport technology	Vulnerability -> affects product -> exploited-by actor/campaign -> targets sector.	Join CTI with asset inventory and exposure, patch/mitigate based on exploitation and operational impact.
Supply-chain compromise	Vendor/software/organization relationships, campaigns, certificates, infrastructure and update behavior.	Monitor vendor access and software execution paths, build investigation playbooks and contingency controls.
Port/logistics platform disruption	Campaign and impact behaviors tied to terminal, booking, cargo, customs or EDI dependencies.	Monitor identity, API, web application and network behavior, include business continuity escalation.

Telemetry reality check

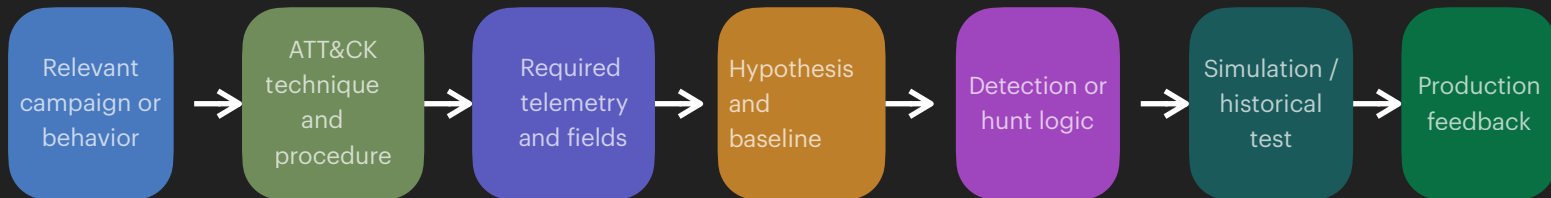
OpenCTI can tell defenders what to look for, but it cannot create missing telemetry. Each use case requires a coverage record: required data sources, actual fields, retention, quality, blind spots and responsible team.

Shipboard environments may have intermittent connectivity, legacy systems and safety constraints. Design hunts and dissemination schedules accordingly.

Evidence source	Examples	If missing
Identity	Entra ID/M365 sign-in, VPN, privileged access, service accounts.	Identity-based PIRs cannot be validated reliably.
Endpoint	Process, ancestry, file, registry/service/task, user and network events.	Behavioral detection is limited, IOC matches have weak context.
Network	DNS, proxy, firewall, flow, remote access and satellite/shore gateway telemetry.	Infrastructure and C2 assessment remains incomplete.
Cloud/SaaS	M365, Azure, GCP and application audit logs.	Token abuse, mailbox manipulation and API activity may be invisible.
Ship/OT	Approved monitoring, asset inventory and vendor access records.	Do not claim detection coverage for vessel systems.

13. CONVERT INTELLIGENCE INTO DURABLE HUNTS AND DETECTIONS

The most valuable OpenCTI output for detection engineering is a defensible hypothesis, not a list of hashes.



Detection engineering template

Field	Required content
Hypothesis	If an adversary abuses remote administration against fleet/shore systems, we should observe a rare remote tool or service followed by unusual authentication and outbound activity.
Evidence basis	OpenCTI report/campaign relationships, source references, dates, confidence and ATT&CK, technique.
Telemetry	Exact Elastic data streams, ECS fields, expected retention and blind spots.
Behavior logic	Parent-child/process ancestry, user context, destination/ASN/domain age where available, frequency, asset role and temporal sequence.
Baseline	Approved tools, vendor accounts, maintenance windows, common destinations and per-host/user frequency.
Exclusions	Full execution and operational context, never whitelist a dual-use binary solely by name.
Validation	Known-positive simulation or replay, historical backtest, negative control, false-positive review and performance test.
Lifecycle	Owner, review date, intelligence dependency, ATT&CK; mapping, tuning record and rollback.

Example hunt: remote administration abuse

- **Hypothesis:** a threat actor targeting transportation may use legitimate remote-management software through a compromised vendor identity.
- **Required evidence:** endpoint process/network telemetry, authentication records, vendor account inventory, asset role and maintenance windows.
- **Pivots:** process ancestry, signer/hash, installation time, first-seen user/host, destinations, session duration, file transfer, credential access and lateral movement.
- **Assessment:** the remote tool alone is unknown or likely benign. It becomes suspicious through rare context, unapproved identity, unusual timing, unexpected target, follow-on behavior or threat-linked infrastructure.
- **Outcome:** confirmed cases feed sightings and incident reports to OpenCTI; benign findings refine baselines, unsupported intelligence is downgraded or corrected.

14. ACCEPTANCE TESTING AND VALIDATION PLAN

Test with synthetic or publicly shareable data first. Do not use production client evidence to prove access segregation or connector behavior unless handling is approved.

Test	Expected result	Evidence
Platform restart	All services recover, no data loss, connectors resume without uncontrolled replay.	Compose status, health, queue and object counts.
Backup restore	A clean test deployment restores search/object data within approved RTO/RPO.	Timestamped restore record and sampled graph objects.
RBAC/markings	Representative users see only allowed objects and cannot export beyond maximum shareable marking.	Access test matrix and screenshots/logs.
Connector failure	Failure is detected, no silent stale state, work can be retried safely.	Alert, connector work log and recovery result.
Deduplication	Repeated bundle does not create uncontrolled duplicate entities/relationships.	Before/after counts and object history.
Confidence ceiling	Low-trust connector cannot overwrite higher-confidence analyst knowledge.	Controlled update test.
Indicator expiry	Score decays, indicator is revoked/detection=false at expected point.	Lifecycle record and downstream update.
Elastic delivery	Only approved objects arrive; mappings are correct, update/revoke/delete semantics work.	Staging index events and rule behavior.
Analyst workflow	A report completes triage, assessment, operationalization and feedback with ownership.	Linked OpenCTI objects and evidence.

Go-live criteria

- No unresolved critical security exposure or data-loss risk.
- Restore test passed and monitoring covers platform, dependencies and connectors.
- RBAC/markings verified with non-admin accounts.
- Source register and connector ownership approved.
- Indicator lifecycle and Elastic revocation behavior verified.
- Pilot data is relevant enough that analysts can explain why each source remains enabled.
- Runbook, escalation path, maintenance window and rollback are approved.

15. IMPLEMENTATION ROADMAP

Window	Technical work	Operational output	Exit gate
Baseline	Inventory deployment, pin versions, review ingress, secrets, volumes, health and backups, establish staging.	Current-state diagram, risk register, owners and restore plan.	Platform is supportable or remediation plan is approved.
Governance	Approve PIRs, source register, taxonomy, workflows, confidence, markings, RBAC and indicator decay.	CTI operating standard and analyst template.	Representative access and lifecycle tests pass.
Pilot ingestion	Enable two approved import sources and one enrichment source; monitor volume, duplicates, relationships and queues.	Pilot dataset and weekly quality report.	Relevance and quality thresholds met.
Elastic path	Configure filtered staging delivery, map fields, test create/update/revoke/delete; build one threat-match and one behavioral use case.	End-to-end technical evidence.	No stale IOC behavior, alert context is sufficient.
Operationalize	Run analyst workflow, tabletop/ validation, train consumers, establish review cadence and backlog.	Production runbook, KPI baseline, lessons learned and roadmap.	acceptance criteria signed off.

Suggested XXXX subtasks

Subtask	Deliverable
Inventory Docker/OpenCTI deployment.	Sanitized architecture and version/health evidence.
Define maritime PIRs and consumers	Approved requirements matrix.
Design RBAC, markings and confidence	Tested access matrix and scoring standard.
Onboard pilot sources/connectors	Connector register and quality report.
Configure indicator decay and dedup tests	Lifecycle and duplicate test evidence.
Build OpenCTI-to-Elastic staging path	Field mapping and create/update/revoke validation.
Implement maritime use case	Hunt/detection plus test result.
Create runbook, KPIs and handover	Operational acceptance pack.

16. METRICS THAT DEMONSTRATE UTILITY WITHOUT INVENTED ROI

Do not reuse unsupported claims such as 60% faster detection or 40% fewer false positives. Establish local baselines, define measurement windows and report distributions rather than isolated success stories.

Metric	Definition	Why it matters
PIR coverage	Percentage of active PIRs with approved sources, owners and at least one operational consumer.	Measures requirement alignment.
Source usefulness	Percentage of source items that become relevant knowledge, hunts, detections, investigations or briefings.	Identifies feeds that add noise.
Stale indicator rate	Active downstream indicators that are expired/revoked in OpenCTI. Target should approach zero.	Tests lifecycle integrity.
Time to assess	Median and 90th percentile from ingestion to analyst assessment for priority items.	Measures workflow, not vendor marketing.
Relationship completeness	Sampled percentage with provenance, dates, confidence and meaningful relationships.	Measures graph quality.
Connector reliability	Successful work ratio, last successful run, backlog and mean recovery time.	Measures operational health.
Hunt/detection conversion	Validated intelligence items producing a durable hunt, detection, control change or documented no-action decision.	Measures operationalization.
Feedback closure	Percentage of disseminated priority items receiving outcome feedback by review date.	Measures learning loop.

Weekly quality dashboard

- Ingested objects by source and type, new relationships, duplicates/merges, rejected/malformed items.
- Active versus expired/revoked indicators, items missing valid-until or provenance.
- Items mapped to maritime PIRs, items with no consumer or action.
- Connector failures, work queue backlog, index/disk health and last successful backup.
- Analyst assessment outcomes: confirmed malicious, suspicious, likely benign and unknown.

17. PRODUCTION RUNBOOK - MINIMUM PROCEDURES

Procedure	Trigger	Required actions
Connector stopped/stale	No successful work inside agreed interval.	Check container/work logs and queue, disable if corrupting data, preserve evidence, retry safely, assess missed or duplicated content.
Unexpected ingestion spike	Volume exceeds baseline or resource threshold.	Identify source/object type, pause connector, check upstream change, duplicates, markings and worker/index health.
Bad intelligence disseminated	False positive, wrong attribution, prohibited sharing or malformed indicator.	Stop distribution, revoke/correct object, notify consumers, verify downstream removal, record source-quality impact.
Credential/token exposure	Token in repository, ticket, logs or unauthorized location.	Revoke/rotate, review access logs, replace secret storage, assess unauthorized API or connector activity.
Platform degradation	Queue backlog, search cluster health, disk or worker failure.	Protect data integrity, stop nonessential ingestion, engage platform owner, restore/scale per approved procedure.
Upgrade	Approved maintenance or security need.	Backup, review release notes, test staging, validate connectors and schema, deploy with rollback, run smoke tests.
Client/partner deletion request	Contractual, legal or sharing correction.	Identify marked data and derived relationships, obtain authorization, remove/correct, verify feeds/exports and audit outcome.

Daily checks

- Platform and dependency health.
- Connector last successful work and error queue.
- Disk/index/queue capacity.
- Priority unassigned items.
- Expired/revoked indicators delivered downstream.

Weekly checks

- Source quality and relevance.
- PIR backlog and operational outcomes.
- Merge/dedup anomalies.
- Access/markings exceptions.
- Backup completion and recovery readiness.

Monthly/quarterly checks

- Restore test or scheduled recovery exercise.
- Version and connector lifecycle review.
- PIR and source register review.
- RBAC/markings recertification.
- Detection/hunt feedback and metric trend review.

18. IMPLEMENTATION CHECKLIST

Status	Domain	Acceptance statement
[]	Platform	Version/images pinned, compose controlled, health stable, persistent storage documented, monitoring and backup/restore tested.
[]	Security	HTTPS, SSO/MFA or strong named accounts, no public data-service ports; secrets protected, connector identities isolated.
[]	Requirements	Maritime PIRs approved, data consumers and actions named, telemetry gaps documented.
[]	Model	Entity/relationship conventions, labels, aliases, provenance and ATT&CK, mapping rules documented.
[]	Governance	Source register, reliability/confidence, max confidence, TLP/client markings and workflows configured.
[]	Lifecycle	Valid dates, decay, revoke behavior, deduplication and bad-data correction tested.
[]	Connectors	Purpose, scope, owner, image, credentials, confidence, marking, frequency, SLA and rollback recorded.
[]	Elastic	Filtered staging stream, field mapping, update/revoke/delete tests, rule context and suppression validated.
[]	Operations	Runbook, incident path, maintenance, access recertification and quality cadence assigned.
[]	Evidence	One end-to-end maritime use case and acceptance pack completed.

Final decision: OpenCTI utilization is achieved when trusted intelligence is converted into traceable maritime security decisions and the platform can be operated, recovered and corrected safely. Connector count and IOC volume are not success criteria.

19. AUTHORITATIVE REFERENCES

- [1] International Maritime Organization, Maritime cyber risk and MSC-FAL.1/Circ.3/Rev.3, <https://www.imo.org/en/ourwork/security/pages/cyber-security.aspx>
- [2] OpenCTI Documentation, Installation, <https://docs.opencti.io/latest/deployment/installation/>
- [3] OpenCTI Documentation, Upgrade, <https://docs.opencti.io/latest/deployment/upgrade/>
- [4] OpenCTI Documentation, Data model, <https://docs.opencti.io/latest/usage/data-model/>
- [5] OpenCTI Documentation, Connectors, <https://docs.opencti.io/latest/deployment/connectors/>
- [6] OpenCTI Documentation, Deduplication and Data processing, <https://docs.opencti.io/latest/usage/deduplication/> and <https://docs.opencti.io/latest/reference/data-processing/>
- [7] OpenCTI Documentation, Indicators lifecycle and Decay rules, <https://docs.opencti.io/latest/usage/indicators-lifecycle/> and <https://docs.opencti.io/latest/administration/decay-rules/>
- [8] OpenCTI Documentation, Users/RBAC and Marking restrictions, <https://docs.opencti.io/latest/> and platform security administration documentation.
- [9] FIRST, Traffic Light Protocol Version 2.0, <https://www.first.org/tlp/>
- [10] OpenCTI Documentation, Workflows and assignation, <https://docs.opencti.io/latest/usage/workflows/>
- [11] OpenCTI Documentation, Data streaming and integrations, <https://docs.opencti.io/latest/reference/streaming/> and <https://docs.opencti.io/latest/deployment/integrations/>
- [12] BIMCO et al., Guidelines on Cyber Security Onboard Ships, Version 5, https://www.bimco.org/media/s4ddrsfe/2024-11-14-guidelines_on_cyber_security-v5-final.pdf

Version caution

OpenCTI, its connector ecosystem and configuration behavior change over time. Validate every command, environment variable, connector field and Elastic mapping against the installed versions and current official documentation before production use. This guide intentionally does not claim the current environment has any control that has not been evidenced.

20. EXTERNAL ENRICHMENT PRIVACY AND REQUIRED INFORMATION

External Enrichment Privacy

Submitting observables, URLs, domains, IP addresses, files, hashes, report content or client-related information to external enrichment services may disclose sensitive data to third parties.

VirusTotal, public sandboxes, passive DNS providers, reputation services and similar platforms must not be used for client or restricted information until the following have been confirmed:

- Service licensing and permitted usage
- Privacy and data-retention terms
- Client contractual requirements
- TLP and organizational markings
- Data classification and sharing restrictions
- Required internal or client approval
- Availability of private submission or private scanning

Public file or URL submissions may become available to vendors, researchers, customers or other third parties. Sensitive files, internal URLs, credentials, tokens, client identifiers and non-public infrastructure must never be submitted without explicit authorization.

Information Required for the Environment-Specific Implementation

Deployment and Architecture

- Installed OpenCTI version
- Docker Compose files and image versions or digests
- OpenCTI, worker and dependency inventory
- Host operating system, CPU, memory and disk capacity
- Elasticsearch/OpenSearch, Redis, RabbitMQ and MinIO/S3 configuration
- Persistent volumes, storage locations and retention
- Network topology, ingress, egress, reverse proxy and TLS configuration
- Internet exposure and administrative access paths

Sources and Connectors

- Connector types, versions, scope and polling frequency
- Source purpose and supported PIR
- Source reliability and connector confidence ceiling
- Default author, labels and markings
- Licensing, TLP and redistribution restrictions
- Connector owner and operational SLA
- Last successful run, errors, ingestion volume and duplicate rate
- Rollback and bad-data correction procedure

Security and Access Control

- Authentication method, SSO and MFA status
- Local administrator accounts
- Users, groups, roles and capabilities
- TLP and client-specific marking access
- Client and organizational data-segregation requirements
- Connector service accounts and API tokens
- Secrets storage and rotation process
- Audit logging and access-review process
- Publicly exposed services and ports

Data Governance

- Approved maritime and transportation PIRs
- Source reliability and information-confidence model
- Entity, relationship, alias and taxonomy conventions
- Indicator validity, decay and revocation rules
- Deduplication and entity-merging behavior
- Intelligence review and approval workflow
- Client-data handling and external-enrichment policy
- Data retention, deletion and correction requirements

- Feedback and intelligence-expiration process

Elastic Integration

- Elastic Stack and Elastic Security versions
- Integration method: connector, live stream, TAXII, API or other mechanism
- Target indices or data streams
- Included OpenCTI object and indicator types
- Confidence, relevance, marking and validity filters
- Field mappings and enrichment fields
- Detection-rule consumers and suppression logic
- Create, update, revoke, expire and delete behavior
- Staging validation, rollback and failure handling

Operations and Ownership

- Named owner for the CTI capability
- Named owners for OpenCTI, Docker, connectors and Elastic integration
- Responsibilities for L1, L2, L3 and detection engineering
- Platform and connector monitoring
- Backup method, frequency and retention
- Latest restoration test and result
- Recovery time and recovery point objectives

- Change-management and upgrade procedure
- Incident, connector-failure and bad-intelligence runbooks
- Available analyst capacity and realistic review workload

Validation and Implementation Evidence

- Current-state architecture diagram
- Connector and source inventory
- RBAC and marking test results
- Backup and restoration evidence
- Indicator lifecycle and revocation test
- Elastic create, update, revoke and delete validation
- One end-to-end maritime intelligence use case
- Resulting hunt, detection, investigation or control decision
- Agreed minimum viable capability, implementation phases and owners

No production integration, automated dissemination or response action should be enabled until the applicable security, privacy, licensing, access-control and lifecycle requirements have been validated.